

Guia: Backend em Python com Seguranca

Passo a passo para armazenar CPF, dados bancarios/PIX e senhas com seguranca

1

Montar a API basica

Use FastAPI (recomendado, tem validacao de dados embutida via Pydantic e e rapido de aprender) ou Flask. Instale com 'pip install fastapi uvicorn'. Crie endpoints separados: um para autenticacao (login com CPF+senha) e outro para receber o formulario de cadastro.

2

Hash de senha com bcrypt (via passlib)

Nao guarde senha de jeito nenhum reproduzivel. Use a biblioteca 'passlib' com bcrypt: 'pip install passlib[bcrypt]'. No cadastro, salve o hash da senha (nunca a senha em texto). No login, compare o hash, nunca a senha original.

3

Criptografar CPF e dados bancarios antes de salvar

CPF e dados bancarios/PIX precisam ser recuperaveis (voce vai precisar mostrar/usar depois), entao nao da pra usar hash - use criptografia simetrica reversivel. A biblioteca 'cryptography' (pip install cryptography) com Fernet resolve isso: voce gera uma chave secreta uma vez, guarda ela fora do codigo (variavel de ambiente), e usa pra criptografar antes de salvar e descriptografar quando precisar ler.

4

Escolher e proteger o banco de dados

Use PostgreSQL (mais robusto pra dado sensivel) com SQLAlchemy, ou SQLite so se for teste local. Nunca deixe o banco acessivel publicamente na internet - so o backend deve falar com ele, com usuario/senha fortes e, se possivel, restrito por IP.

5

Guardar segredos em variaveis de ambiente

Chave de criptografia, senha do banco, e qualquer credencial NUNCA vao dentro do codigo nem em arquivos que vao pro GitHub. Use um arquivo '.env' (com a biblioteca 'python-dotenv') e coloque '.env' no '.gitignore'. Em producao, configure essas variaveis diretamente no servidor/hospedagem.

6

Salvar o consentimento com timestamp

Ao criar o endpoint de aceite de privacidade (Etapa 03), salve no banco uma linha com: CPF do colaborador, texto/versao dos termos aceitos, data e hora exata (datetime.now()). Isso vira sua prova de consentimento.

7

Ativar CORS restrito e forcar HTTPS em producao

Configure CORS no FastAPI (biblioteca embutida) pra so aceitar requisicoes vindas do dominio do seu proprio frontend, nao de qualquer site. E em producao, o servidor so deve aceitar conexoes HTTPS (a hospedagem geralmente cuida disso com um proxy tipo Nginx + Let's Encrypt na frente do FastAPI).

8

Testar se os dados realmente estão protegidos

Antes de ir ao ar: cadastre um usuário de teste, veja se a senha salva no banco está em formato de hash (não legível), veja se o CPF/PIX salvo está criptografado (não legível direto no banco), e confirme que só quem tem a chave certa consegue descriptografar.

Stack sugerida: FastAPI + passlib (bcrypt) + cryptography (Fernet) + PostgreSQL + python-dotenv.